

COM6022M – Assessment 1

Cloud Migration and Security Planning for TechLink Solutions

Student Number: 250226267

Contents

Assumptions made	3
Organisational Assessment	3
Readiness Scorecard	4
Cloud Adoption Strategy	4
Security and Compliance Planning.....	5
Migration Roadmap	6
Executive Summary.....	7
References.....	8

Table of Figures

Figure 1: Readiness Scoreboard for TechLink Solutions	4
---	---

Assumptions made

The company TechLink Solutions operates under the jurisdictions of the United Kingdom and is subject to the UK GDPR and the Data Protection Act from 2018 (ICO, 2018). The company processes personal data and financial transaction records from their customers and the company, making PCI-DSS compliance applicable (PCI Security Standards Council, 2022). The IT team of eight employees has a foundational cloud understanding but don't possess certifications. The annual budget for the IT department allows phased investment over a year and a half, transitioning from a capital expenditure model to an operational expenditure model. The web application handles from moderate to a high traffic with potential seasonal spikes.

Organisational Assessment

TechLink Solutions has clear business drivers for migration, these changes must be applied with urgency. The fast and consistent growth over the past two years has exposed the existing limits of fixed infrastructure located on premise, this limitation has caused traffic outages and hardware failures which directly threaten service availability and reliability.

Evaluating the readiness across existing infrastructure, security, and governance reveals that the core system has not scaled alongside the company's growth, which has left critical gaps in resilience and compliance.

The infrastructure is not prepared for the traffic being dealt with. Fixed hardware limits scalability and cannot absorb traffic spikes. Manual patch management consumes IT resources disproportionately and introduces security risk through a delay fixing vulnerabilities, the absence of DDoS protection leaves the public-facing web application open to availability attacks which may lead to reputational and consequently commercial damage. Nightly backups on site is a limited disaster recovery posture, a failure in this site would lead to up to 24 hours of data loss. Microsoft (2023a) identifies inadequate disaster recovery as one of the most significant risks organisations face prior to cloud adoption.

This growth has made TechLink a potential target for attackers and malicious software, its security posture has not scaled accordingly. Basic perimeter security, firewalls, and antivirus are insufficient against modern threats including malware, intrusion attempts, and possible insider attacks (Hashizume et al., 2013). The system has no IAM framework, no existing network segmentation strategy, and no documented encryption policy set up.

The absence of a cloud governance framework confirms there are no policies for cost control, access permissions, or the monitoring of compliance. Microsoft (2024a) states that without a governance framework, organisations risk misconfiguration, cost overruns, and compliance violations in cloud environments.

The capability of the staff is a sufficient starting point for the migration to a hybrid model, but structured upskilling is necessary before the migration takes place.

Readiness Scorecard

Dimension	Score (1 to 5)	Status	Justification
Infrastructure Flexibility	1	Critical	Fixed on-premises hardware with no elasticity or redundancy.
Security Posture	2	Critical	Perimeter only security. No IAM, segmentation, or encryption policy.
Disaster Recovery	2	Critical	On-premise nightly backups only. No off-site or geo-redundant recovery.
Cloud Governance	1	Critical	No governance framework, policies, or cost controls exist
Staff Capability	3	Moderate	Foundational cloud awareness. Formal training is required.
Business Driver Clarity	5	Strong	Clear urgency. Growth pressures, outages, and client expectations to be met.
Overall Readiness	2.3	Not Ready	Significant gaps must be addressed and sorted prior to migration.

Figure 1: Readiness Scoreboard for TechLink Solutions

Before the initiation of the migration process, TechLink Solutions needs to establish a baseline governance policy, begin staff training aligned to the provider's certification, and importantly, it must develop a documented security baseline covering encryption and IAM to satisfy regulatory obligations. This aligns with the Strategy and Plan phases of the Microsoft Cloud Adoption Framework (Microsoft, 2024a).

Cloud Adoption Strategy

A hybrid cloud deployment model is the most suitable for TechLink Solutions, an exclusively public approach would be concerning around the customer database regarding UK GDPR data residency (ICO, 2021). An exclusively private cloud does not address scalability. The hybrid model allows resources like the customer web application to run publicly, while the more sensitive data remains in a controlled environment, satisfying both performance and compliance requirements simultaneously.

The simultaneous use of IaaS and PaaS is recommended for the service model. The web application should be moved to a PaaS environment like Azure App Service, removing OS and runtime management from the limited IT resources available. Under the shared responsibility model, the cloud provider manages the infrastructure stack while TechLink Solutions retains responsibility for the application and sensitive data (Amazon Web Services, 2023).

The relational database should migrate to a DBaaS like Azure SQL Database, ensuring automated backups, database replication in case of emergency, and geo-redundancy with the use of different zones while preserving similar SQL semantics. Internal analytics services are strong candidates for SaaS solutions, lowering the operational expenses further.

The recommendation is Microsoft Azure. A platform with native UK GDPR compliance, integration with Microsoft Entra ID for IAM, and encryption tooling through the use of Azure Key Vault, allowing TechLink's compliance requirements to be met (Microsoft, 2024b).

High availability must be a priority and has to be architected at the beginning of the migration process. The use of a load balancer should sit at the front of the web application tier, allowing the system to distribute traffic across at least two available instances in separate availability zones. These load balancers have the ability to automatically detect and bypass instances that do not appear healthy, a benefit that directly addresses TechLink's documented failure modes (Microsoft, 2023b). In the case of a potential disaster, Azure Site Recovery and geo-redundant storage can replace the nightly backups, allowing recovery times to be measured in hours instead of days.

Security and Compliance Planning

The protection of data must be the most critical concern in systems that have access to sensitive data. All customer personal data and transaction records are subject to the UK GDPR and PCI-DSS, requiring encryption of both data at rest and in transit. AES-256 is the industry standard for encryption at rest and is applied natively through Azure Storage Service Encryption (Microsoft, 2023c).

On the database tier, Transparent Data Encryption (TDE) should be enabled on Azure SQL Database, automatically encrypting data files and transaction logs without application changes (Microsoft, 2023d). Dynamic Data Masking (DDM) should be configured to conceal sensitive columns including customer email addresses, card details, and passwords from non-privileged database users, limiting exposure without modifying the underlying data (Microsoft, 2023e).

The encryption keys must be stored in Azure Key Vault under customer-managed key (CMK) configuration, allowing TechLink to retain full control over key rotation and revocation (Microsoft, 2024b). Data in transit must use TLS 1.2 or later to ensure end-to-end encrypted communication between customer browsers and the web application server (Internet Engineering Task Force, 2018).

The absence of Identity and Access Management is a serious concern. The migration must introduce role-based access control (RBAC) across all cloud resources from release, enforcing least privilege (Sandhu and Samarati, 1994). Azure Entra ID should serve as the identity provider with multi-factor authentication enforced for all accounts. The use of Privileged Identity Management (PIM) will provide time-based administrative access; these privileges must be revoked once no longer necessary. In the case of accessing a specific VM, Just-In-Time (JIT) access should be configured so that ports are only open on explicit request for a defined time window, reducing vulnerability to external attacks (Microsoft, 2023f). Azure Bastion should serve as the singular gateway for RDP and SSH access, eliminating the need to expose ports directly to the internet (Microsoft, 2023g).

Network security requires depth. VNets should segment the database, web application, and analytics tiers into separate subnets with NSGs controlling traffic flows between them — no direct internet access should reach the database subnet. The Web Application Firewall at the perimeter addresses the absence of DDoS protection, with Azure DDoS Protection Standard providing volumetric mitigation (Microsoft, 2023h).

DNS cache poisoning and rebinding attacks pose significant cloud threats and DNS security cannot be overlooked (Kaminsky, 2008). Azure Private DNS zones should be utilised for internal service resolution. As Azure does not natively support DNSSEC, public DNS zones

should be delegated to Cloudflare or Amazon Route 53 for signed resolution, preventing spoofing and cache poisoning (Arends et al., 2005).

Backups must be encrypted via Azure Key Vault and stored in a separate region to protect against site failure. Enabling Soft Delete on Azure Backup vaults guarantees a recovery window against accidental or malicious deletion (Microsoft, 2023i). Backup restoration procedures should be tested quarterly, and testing the Recovery Time Objective (RTO) and Recovery Point Objective (RPO) will ensure backup readiness with accurate measurements.

Azure Monitor and Azure Security Centre will provide continuous posture assessments. Logs from VMs, the database tier, and network flows should be integrated into a SIEM solution such as Microsoft Sentinel, enabling automated anomaly detection and alerting (Microsoft, 2024c). A documented incident response plan must be in place prior to go-live, including a 72-hour breach notification procedure to meet UK GDPR obligations (ICO, 2018).

TechLink Solutions must comply with UK GDPR and PCI-DSS, and the adoption of ISO/IEC 27001 as an information security management framework will provide auditable governance structure across all cloud operations (ISO, 2022). Azure Policy enforces compliant configurations, and the Security Centre compliance dashboard supplies real-time posture visibility.

Migration Roadmap

The migration is divided into three phases over a period of 18 months.

Phase 1: Foundation (Months 1 to 4)

In this initial phase the governance, security, and networking baseline will be established before the migration of any workload. This includes the deployment of VNets and NSGs, configuring IAM and RBAC, deploying Azure Key Vault, enabling Azure Monitor and Security Centre, and establishing S2S VPN connectivity. During this phase staff should begin Azure Fundamentals (AZ-900) and Security (AZ-500) training. The pilot workload used for system testing is internal analytics services, which have low business criticality, making them useful for validating connectivity and security tooling without risk to customer-facing systems.

Phase 2: Database and Application Migration (Months 5 to 12)

The migration of the relational database to Azure SQL Database using Azure Database Migration Service will take place during this phase, with TDE and DDM configured from the beginning. Running in parallel against the on-premises database for four weeks to validate data integrity. The customer-facing web application must migrate to Azure App Service behind Application Gateway with WAF enabled and load balancing across a minimum of two availability zones. Penetration testing and performance benchmarking must complete before traffic cutover (NCSC, 2021). Staff training regarding new access procedures and RBAC roles must be finalised during this phase.

Phase 3: Full Deployment and Optimisation (Months 13 to 18)

In this final phase, the on-premises data centre as primary infrastructure will be decommissioned. Focus will shift to tuning autoscaling policies, activating Microsoft Sentinel for SIEM, executing a simulated disaster recovery failover, completing a full GDPR and PCI-DSS compliance audit, and developing a formal incident response playbook.

Executive Summary

TechLink Solutions is confronted with an urgent case for cloud migration. The persistence of outages, constrained infrastructure, and rising client security expectations create both the business need and justification to act. This report recommends a hybrid cloud model on Microsoft Azure, combining PaaS for the customer-facing web application with managed IaaS for the database tier.

The critical benefits are elastic scalability necessary for the mitigation of traffic spike vulnerabilities, geo-redundant disaster recovery replacing the current single-site backup risk, and the OpEx model replacing capital locked in ageing hardware. The security framework proposes a defence in depth approach consisting of: AES-256 with TDE and DDM for the protection of the database tier, TLS for data in transit, RBAC and MFA enforced via Entra ID, JIT access and Azure Bastion for securing VM management, WAF-backed DDoS protection at the perimeter, DNSSEC-capable DNS resolution, Soft Delete backup protection, and SIEM-driven monitoring through Microsoft Sentinel. This framework meets the obligations of UK GDPR and PCI-DSS, and aligns with the ISO/IEC 27001 information security standard (ISO, 2022).

The principal risks this migration faces are the complexity of the process and staff capability. The 18-month roadmap manages these directly. The pilot phase validates tooling before critical data is put at risk, parallel database running reduces cutover risk, and structured training ensures the team operates the environment confidently thereafter. Delaying execution will increase both technical risk and regulatory exposure.

References

- Amazon Web Services (2023) *Shared responsibility model*. Available at: <https://aws.amazon.com/compliance/shared-responsibility-model/> (Accessed: 11 May 2026).
- Arends, R., Austein, R., Larson, M., Massey, D. and Rose, S. (2005) 'DNS Security Introduction and Requirements', *RFC 4033*, Internet Engineering Task Force. Available at: <https://www.rfc-editor.org/rfc/rfc4033> (Accessed: 11 May 2026).
- Hashizume, K., Rosado, D.G., Fernández-Medina, E. and Fernandez, E.B. (2013) 'An analysis of security issues for cloud computing', *Journal of Internet Services and Applications*, 4(5), pp. 1–13.
- ICO (2018) *Data Protection Act 2018*. Available at: <https://ico.org.uk/for-organisations/data-protection-act-2018/> (Accessed: 11 May 2026).
- ICO (2021) *Guide to the UK GDPR*. Available at: <https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/> (Accessed: 11 May 2026).
- Internet Engineering Task Force (2018) *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446. Available at: <https://www.rfc-editor.org/rfc/rfc8446> (Accessed: 11 May 2026).
- ISO (2022) *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection*. Available at: <https://www.iso.org/standard/27001> (Accessed: 11 May 2026).
- Kaminsky, D. (2008) 'It's the end of the cache as we know it', *Black Hat USA 2008*. Las Vegas: Black Hat.
- Microsoft (2023a) *Business continuity and disaster recovery*. Available at: <https://learn.microsoft.com/en-us/azure/reliability/business-continuity-management-program> (Accessed: 11 May 2026).
- Microsoft (2023b) *What is Azure Load Balancer?* Available at: <https://learn.microsoft.com/en-us/azure/load-balancer/load-balancer-overview> (Accessed: 11 May 2026).
- Microsoft (2023c) *Azure Storage encryption for data at rest*. Available at: <https://learn.microsoft.com/en-us/azure/storage/common/storage-service-encryption> (Accessed: 11 May 2026).
- Microsoft (2023d) *Transparent data encryption for SQL Database*. Available at: <https://learn.microsoft.com/en-us/azure/azure-sql/database/transparent-data-encryption-tde-overview> (Accessed: 11 May 2026).
- Microsoft (2023e) *Dynamic data masking*. Available at: <https://learn.microsoft.com/en-us/azure/azure-sql/database/dynamic-data-masking-overview> (Accessed: 11 May 2026).
- Microsoft (2023f) *Just-in-time VM access*. Available at: <https://learn.microsoft.com/en-us/azure/defender-for-cloud/just-in-time-access-usage> (Accessed: 11 May 2026).
- Microsoft (2023g) *What is Azure Bastion?* Available at: <https://learn.microsoft.com/en-us/azure/bastion/bastion-overview> (Accessed: 11 May 2026).

Microsoft (2023h) *Azure DDoS Protection overview*. Available at: <https://learn.microsoft.com/en-us/azure/ddos-protection/ddos-protection-overview> (Accessed: 11 May 2026).

Microsoft (2023i) *Soft delete for Azure Backup*. Available at: <https://learn.microsoft.com/en-us/azure/backup/backup-azure-security-feature-cloud> (Accessed: 11 May 2026).

Microsoft (2024a) *Microsoft Cloud Adoption Framework for Azure*. Available at: <https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/> (Accessed: 11 May 2026).

Microsoft (2024b) *Azure Key Vault overview*. Available at: <https://learn.microsoft.com/en-us/azure/key-vault/general/overview> (Accessed: 11 May 2026).

Microsoft (2024c) *What is Microsoft Sentinel?* Available at: <https://learn.microsoft.com/en-us/azure/sentinel/overview> (Accessed: 11 May 2026).

NCSC (2021) *Penetration testing*. Available at: <https://www.ncsc.gov.uk/guidance/penetration-testing> (Accessed: 11 May 2026).

PCI Security Standards Council (2022) *PCI DSS v4.0*. Available at: https://www.pcisecuritystandards.org/document_library/ (Accessed: 11 May 2026).

Sandhu, R.S. and Samarati, P. (1994) 'Access control: Principles and practice', *IEEE Communications Magazine*, 32(9), pp. 40–48.